Lab 5: Static Code Analysis

Student: Ruthik **SRN:** PES1UG25CS837

Program: Energy Consumption & Tariff Calculator (`energy_system.py`)

Objective

Use Pylint, Bandit, and Flake8 to find code-quality, security, and style problems, fix them, and verify the fixes by rerunning the tools.

Issue table

Issue	Category	Original location	Fix made
Mutable default history=[]	Correctness	Original line 12	Default changed to None; create a new list when needed.
eval(adjustment)	Security	Original line 63	Replaced eval with integer parsing and validation.
Bare except	Reliability	Original line 44	Catch specific file, encoding, and JSON errors.
File handles not safely managed	Resource handling	Original lines 42–49	Use Path.read_text/write_text with UTF-8.
Negative unit readings accepted	Input validation	Original line 55 example	Reject negative readings and require integer units.
Unused sys import	Maintainability	Original line 2	Removed unused import.
Program executes on import	Testability	Original line 68	Added __main__ guard.

Reflection answers

1. What is static code analysis? It examines source code without running it to find possible bugs, security weaknesses, and style issues.

2. What does Pylint do? It checks Python code quality, naming, structure, unused imports, and potential mistakes.

3. What does Bandit do? It scans Python code for common security risks, such as unsafe use of eval.

4. What does Flake8 do? It checks Python formatting and style, including many PEP 8 rules.

5. Why run tools before and after fixing code? The first run records the original findings; the second checks whether changes removed them and whether problems remain.

6. What did you learn? Static analysis can identify risky or hard-to-maintain code early. Fixing unsafe evaluation, broad exception handling, shared mutable defaults, and file handling improves safety and reliability.

Verification note: This document summarizes the changes prepared in the corrected script. Actual after-report outputs and the Pylint score must be generated on the project computer and checked before submission. Do not claim a score or clean scan until confirmed by the tools.